



Federal Office
for Information Security

Technical Guideline BSI TR-03145

Secure CA operation

Part 1: Generic requirements for a Certification Authority in a Public Key Infrastructure with security level 'high'

Version 2.0.0

08.08.2025



Federal Office for Information Security
P.O. Box 20 03 63
53133 Bonn
Tel.: +49 22899 9582-0
E-Mail: eID@bsi.bund.de
Internet: <https://www.bsi.bund.de>
© Federal Office for Information Security 2025

Table of Contents

1	Introduction.....	6
1.1	Public Key Infrastructures.....	6
1.2	Scope of this document	6
1.3	Audit and certification	7
1.3.1	Scope of audit and certification	7
1.4	Concept and structure of this document	8
2	General requirements for Certification Authorities.....	9
2.1	Cryptographic measures	9
2.2	Certification Practice Statement and Certificate Policy management.....	9
2.2.1	Certificate policy management.....	9
2.2.2	Certification practice statement management.....	10
2.2.3	Requirements for relying parties and subscribers of the CA	11
2.3	Information security policy.....	11
2.4	Asset classification and management.....	11
2.5	Human resources security.....	11
2.6	Physical and environmental security	12
2.7	Operational security.....	12
2.8	Access control	13
2.9	System acquisition, development and maintenance	13
2.10	Business continuity management.....	13
2.11	Monitoring, conformance and compliance	14
2.12	Audit journal security and archiving	14
2.13	Controlled CA termination	15
3	Key life cycle management.....	16
3.1	CA key life cycle management.....	16
3.1.1	CA key generation.....	16
3.1.2	CA key storage, backup, and recovery.....	16
3.1.3	CA public key distribution	17
3.1.4	CA key usage	17
3.1.5	CA key archival and destruction.....	17
3.1.6	CA key compromise.....	17
3.2	Subject key life cycle management.....	18
3.2.1	Subject key generation and distribution	18
3.2.2	Subject key storage, backup and recovery	19
3.2.3	Hardware token life cycle management (if supported).....	20
3.2.4	Subject key archival and destruction (if supported).....	20

4	Certificate life cycle management	22
4.1	Subject registration.....	22
4.2	Certificate renewal (if supported).....	22
4.3	Certificate rekey.....	23
4.4	Certificate issuance.....	23
4.5	Certificate distribution.....	24
4.5.1	Directory Service (if supported)	24
4.6	Certificate changeover (if supported)	24
4.7	Certificate revocation	25
4.8	Certificate suspension (if supported)	26
4.9	Revocation status information service.....	27
4.10	Validation Model.....	27
	Bibliography	28

Abbreviations, definitions and keywords

This document uses abbreviations and definitions of terms as defined in (ISO27099). Table 1: Abbreviations and Definitions

below contains additional abbreviations and additional or modified definitions of terms relevant for this document. See also (ETSI102042) and (RFC3647) for further CA and PKI related concepts and terminology.

Abbreviation	Term	Definition
CRL	certificate revocation list	According to (ETSI102042) a ' <i>cryptographically signed list indicating a set of certificates that are no longer considered valid by the issuing CA</i> '.
CA	certification authority	According to (ETSI102042) an ' <i>authority trusted by one or more entities to create and assign certificates</i> '.
	subject	According to (ETSI102042) an ' <i>entity identified in a certificate as the holder of the private key associated with the public key given in the certificate</i> '. Note: A subject may be simultaneously a subscriber within the PKI.
	subscriber	According to (ETSI102042) an ' <i>entity subscribing with a Certification Authority on behalf of one or more subjects</i> ' and that ' <i>may be a subscriber acting on its own behalf</i> '.
TR	Technical Guideline	

Table 1: Abbreviations and Definitions

The key words "MUST," "MUST NOT," "REQUIRED," "SHALL," "SHALL NOT," "SHOULD," "SHOULD NOT," "RECOMMENDED," "MAY," and "OPTIONAL" in this document are to be interpreted as described in (RFC2119). Irrespective of capitalisation, the same holds for all referenced "control procedures" of (ISO27099).

1 Introduction

1.1 Public Key Infrastructures

A Public Key Infrastructure (PKI) enables the establishment and management of trust relationships between different entities.

A PKI is based on the principle of asymmetric cryptography. With asymmetric cryptography, a key pair is created. This key pair consists of a private (i.e. secret) key and a public key. Data encrypted with the public key can only be decrypted with the corresponding private key. Encryption is used to keep data confidential. In addition, it is possible to digitally sign data with the same private key. The associated public key can then be used to check whether the data has been changed since the signature. Digital signatures are used to make modifications of data transparent and thus, to ensure the integrity of the signed data.

The most important tool within a PKI is the certificate. A certificate binds the public key of a key pair to the identity of an entity (e.g. person or organization). I.e., a certificate contains the public key of a key pair together with other information, such as who issued the certificate, for whom it was issued and how long the certificate is valid. A certificate is issued by a Certification Authority (CA) and signed by this Certification Authority with its private key. It is the certification of trust in the certificate holder by the issuing Certification Authority.

Although there are many different structures of PKI, this document only considers hierarchical PKIs. In a hierarchical organized PKI the topmost instance of the PKI is the so-called root-CA. The root-CA serves as anchor of trust within a PKI and signs its own certificate. Furthermore, it either signs and disseminates end entity certificates or, and this is the general case, signs and disseminates one or more certificates for so-called sub-CAs. Sub-CAs, whose associated certificates were signed with the private key of the root-CA, can in-turn use their private key to sign certificates of other entities. Theoretically, a chain like this can be any length as long as it starts with the root certificate. To check the authenticity and trustworthiness of a certificate from a PKI, the certificates of all CAs that lie between the entity to be checked and the root-CA must be verified.

The business of a PKI is a business of trust. This document contributes to the establishment and management of trust in a PKI in two ways:

First, the document at hand defines requirements for secure operation of a CA. By implementing these organizational and technical security measures, security level 'high' according to Part 1 of Technical Guideline (BSI-TR-03107) is achieved by a CA.

Secondly, this document enables the transparent and comparable demonstration that a CA effectively and completely implements these security measures and thus, achieves security level 'high'. In order to do so, an audit of the CA is performed based on the requirements from this document by a trusted independent auditor and certified by a trusted certification body.

Both together build the basis which legitimates the trust in a CA.

1.2 Scope of this document

This document is part 1 of the Technical Guideline series (BSI-TR-03145) defining requirements for the operation of a CA with security level 'high'. The other documents of the series consider additional or modified requirements for specific business cases. Unless stated otherwise in specific parts of this series, security level 'high' applies for all documents in this series.

The document at hand describes generic requirements for the secure operation of a CA. Therefore, a CA shall implement an Information Security Management System (ISMS) in order to establish, maintain and improve information security.

Generic requirements for the operation of such an ISMS are covered by (ISO27001). However, due to its generic character it does not reflect specific requirements for an ISMS in the context of CA operation. This

gap has been closed by previous versions of (BSI-TR-03145). A CA can be audited and certified according to (ISO27001) by using versions 1.0 and 1.1 of (BSI-TR-03145) as sector-specific requirements for secure CA operation. Such certifications have been successfully performed various times by different CA operators and for different CA business cases.

Now, with (ISO27099) an international standard is published that adapts the use of an ISMS to the specific application of CA operation. Unfortunately, it is not (yet) possible to perform an audit and certification of a CA according to (ISO27099). This gap is closed by this document: It is possible for CAs to be certified by an accredited ISO/IEC 27001 certification body using this document, in conjunction with its references to (ISO27099), as sector-specific requirements. That way, the already established certification scheme from the previous versions of this Technical Guideline is transferred to the new ISO standard (ISO27099). As for previous versions of this Technical Guideline or (ISO27099), all requirements, including references to (ISO27099), SHALL be considered as part of and in the context of an ISMS implemented according to (ISO27001).

1.3 Audit and certification

Audit and certification according to this Technical Guideline create trust in a CA by providing evidence that a CA is compliant with the requirements from this Technical Guideline and achieves security level 'high'.

As mentioned above, it is possible for CAs to be certified by an accredited ISO/IEC 27001 certification body using this document, in conjunction with its references to (ISO27099), as sector-specific requirements. This implies that the scope of the ISMS of the CA includes the entire CA operation and includes the following requirements:

- the CA is audited by an independent, external and accredited ISO/IEC 27001 auditor,
- that this audit is performed and repeated on a regular basis (annual surveillance audit),
- that the scope of this audit also covers the requirements defined in the document at hand.

For the detailed information about carrying out conformity evaluations in line with Technical Guidelines, see also information on the BSI website <https://www.bsi.bund.de> (e.g.

https://www.bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Zertifizierung-und-Anerkennung/Zertifizierung-von-Produkten/Zertifizierung-nach-TR/Pruefbereiche/pruefbereiche_node.html.)

1.3.1 Scope of audit and certification

This Document, Part 1 of BSI TR-03145, defines requirements for the secure operation of a single CA in a PKI. This CA SHALL be uniquely identified in its own certificate as subject. Furthermore, its relationship within the PKI SHALL be clearly specified. This SHALL consist of a complete description of

- all CAs the PKI consists of whereas these CAs are all uniquely identified in their certificate as subject,
- the PKI hierarchy, and
- all other PKI components or services that may be relevant for the security of the CA, such as for example Registration Authority, Directory Service or CRL Signer (if supported).

As the business of root-CA and sub-CA is very similar, almost all requirements specified in the document at hand apply to both. Therefore, the general term CA is used in this document. For the few aspects which might differ, it will be mentioned explicitly.

Despite the general character of the requirements from this document, the individual implementation of these requirements vary. In general, the individual implementations of technical or organizational security measures differ between root-CA and sub-CA and sometimes even between different sub-CAs within the same PKI. I.e. this document is meant as the basis for the audit and certification of a single CA. Nonetheless, an audit according to Part 1 or other application specific parts MAY be performed for more than one single

CA within the same PKI or for all CAs within the same PKI. In that case, audit and corresponding audit report SHALL contain all relevant information including scope of audit and any differences between the CAs.

For more details, see the corresponding Inspection Specifications document.

1.4 Concept and structure of this document

In order to ease the application of this document in conjunction with (ISO27099), this document mainly follows the structure of (ISO27099).

However, like previous versions of this Technical Guideline, this version of the Technical Guideline continues to use the term “requirement” instead of the term “control procedure” used in (ISO27099).

The control procedures from Section 7 of (ISO27099) constitute the basis of the requirements for secure CA operation defined by this Technical Guideline. In detail, Sections 2, 3 and 4 of this document adopt and amend the control procedures of Sections 7.2 to 7.15 of (ISO27099) to define the requirements that SHALL be fulfilled for compliance of a CA with this Technical Guideline. In order to be compliant with this Technical Guideline a CA SHALL fulfil all requirements from this document. This SHALL include those requirements which are implicitly contained in this document as a reference to (ISO27099) as well as those requirements which are explicitly stated in this document.

Throughout this document, “(if supported)” is to be understood as conditional requirement(s). For example, the requirements concerning certificate renewal, see section 4.2, are conditional. That means, a CA MAY allow certificate renewal. If a CA allows certificate renewal, then all requirements specified in section 4.2 SHALL be fulfilled by that CA. Otherwise, these requirement(s) are not applicable.

To enable the balance between flexibility and precision so-called “assignments”¹ are used within this document. These are to be filled in by the CA, thereby enforcing a specification of a single procedure, but also allowing different solutions within defined limits.

Note that the standard (ISO27099) defines a Policy Authority (PA) as a dedicated role. This Technical Guideline does not require the existence of a dedicated Policy Authority. For control procedures from (ISO27099) that require the role of a Policy Authority and that SHALL be fulfilled as requirement according to this document, the responsibilities ascribed to a Policy Authority SHALL be fulfilled by the CA or another appropriate instance under responsibility of the CA.

¹ Note that unlike in previous versions of this Technical Guideline, the requirements in this version do not make use of so-called “selections”.

2 General requirements for Certification Authorities

A CA shall be considered trustworthy by subscribers and relying parties for any of its services. To ensure trustworthiness various aspects have to be considered. This includes for example operational security, security of the infrastructure, physical security and trustworthy personnel. Each of the following subsections covers such security requirements.

2.1 Cryptographic measures

The use of inappropriate cryptographic algorithms or parameters facilitates the compromise of certificates, signatures, hashes or encryption. Therefore, the CA shall ensure that appropriate cryptographic algorithms and parameters are used. The algorithms and parameters shall comply with the current state of the art and shall be based on well-known Technical Guidelines and standards such as for example (BSI-TR-03116), (BSI-TR-02102).

Concerning the cryptographic measures, the following requirement applies:

2.1A1 The CA SHALL ensure that the cryptographic algorithms and their parameters comply with the newest editions of the following documents: [assignment: technical guidelines or standards for cryptographic algorithms and recommended key lengths], which SHALL be chosen depending on the business case of the CA.

The CA SHALL check the cryptographic algorithms and their parameters referring to the newest editions:

- Each time a cryptographic algorithm is newly implemented.
- When an incident of a used algorithm becomes public.
- Regularly, in a period of [assignment: number of days, weeks or months].

2.2 Certification Practice Statement and Certificate Policy management

According to (RFC3647) a Certificate Policy (CP) is a *'named set of rules that indicates applicability of a certificate to a particular community and/or class application with common security requirements'*. A Certificate Policy states "what is to be adhered to".

According to (ISO27099) a Certification Practice Statement (CPS) is issued by a CA and *'defines the equipment, policies, and procedures the CA uses to satisfy the requirements specified in the certificate policies'*. In this context, a CPS is more refined than the CP it conforms to, and describes individual measures in the key and certificate life cycle and their technical realization. A Certification Practice Statement states "how it is adhered to".

This Section refers to Section 7.2 of (ISO27099) and addresses requirements concerning both, Certificate Policy and Certification Practice Statement. With respect to Certificate Policy and Certification Practice Statement, the following requirements apply:

2.2A1 CP and CPS SHALL be part of the documentation which is maintained within the ISMS.

2.2A2 Within a PKI the CPs and CPSs SHALL be compliant. Before issuing a certificate to a CA, the issuing CA SHALL ensure that CP and CPS of the subscribing CA are consistent with its own CP and CPS. A subscribing CA SHALL ensure that its own CP and CPS are consistent with CP and CPS of the issuing CA.

2.2.1 Certificate policy management

Control procedures referenced in this Section refer to Section 7.2.1 of (ISO27099). In order to provide an adequate Certificate Policy, the following control procedures SHALL be fulfilled as requirements:

(1), (4), (6), (7).

Additionally, the following requirements apply:

2.2.1A1 The CP SHALL include a reference to a contact person of the CA.

2.2.1A2 The CP SHALL specify the key and certificate management life cycle processes of the CA comprehensively. At least the following aspects SHALL be covered:

- reference to a document owner for CP related issues
- unique document identification for further reference, i.e. by exact document title, version and unique policy identifier for reference in certificates issued by the CA
- limitations concerning subscribers of the PKI (e.g. company or administration specific PKIs)
- application context of the PKI
- description of subscriber registration procedures including specification of registration data, requirements for data transmission, and description of verification procedures of the CA or RA
- subscriber obligations (e.g. requirements on subscriber key stores and application environment)
- specification of certificate profiles
- validation model of the PKI, need of certificate validation by checking signature and fingerprints
- certificate revocation procedures including revocation reasons, revocation authorization, revocation application mechanisms (if supported)
- certificate status information services
 - CRLs (if supported)
 - OCSP (if supported)
- directory service (if supported)
- key lifecycle security measures
- certificate renewal procedures (if supported)
- CA termination
- CP update procedures

2.2.2 Certification practice statement management

Control procedures referenced in this Section refer to Section 7.2.2 of (ISO27099). In order to provide an adequate Certification practice statement, the following control procedures SHALL be fulfilled as requirements:

(1), (2), (3), (4), (5), (6), (7), (8), (9), (11).

Additionally, the following requirements apply:

2.2.2A1 The CPS SHALL include a reference to a document owner responsible for the document management.

2.2.2A2 The CPS SHALL include a section with document identification of the CPS for further reference, i.e. by exact document title, version and unique policy identifier of the CP which the CPS is corresponding to.

2.2.2A3 The CPS SHALL document all security measures and server and network configurations.

2.2.3 Requirements for relying parties and subscribers of the CA

The CA shall have appropriate agreements in place with the involved parties, i.e. subscribers and relying parties. Additionally, the CA shall disseminate its Terms and Conditions to the subscribers to inform them about the organizational and technical security requirements the subscribers have to fulfil and which duties can be demanded to be fulfilled by the CA and the other subscribers.

Control procedures referenced in this Section refer to Section 7.2.3 of (ISO27099). Concerning requirements for relying parties and subscribers of the CA, the following control procedures SHALL be fulfilled as requirements:

(1), (2), (6).

Additionally, the following requirements apply:

2.2.3A1 The CA SHALL make each version of its Terms and Conditions available to its subscribers and relying parties.

2.2.3A2 Each version of the CA's Terms and Conditions SHALL be uniquely identifiable, e.g. by a unique version number contained in the text.

2.2.3A3 The CA SHALL oblige the subscribers and advise the relying parties, e.g. within its CP or Terms and Conditions, to validate the CA certificate and the subscriber certificates.

2.2.3A4 The dissemination of Terms and Conditions SHALL be protected from manipulation.

2.3 Information security policy

In (ISO27001) information security is defined as '*preservation of confidentiality, integrity and availability of information; in addition, other properties such as authenticity, accountability, non-repudiation and reliability can also be involved*'. A CA shall ensure that information security is established and continuously maintained.

Control procedures referenced in this Section refer to Section 7.3 of (ISO27099). Concerning the information security the following control procedures SHALL be fulfilled as requirements:

(1), (3), (4), (5), (6), (7), (12), (13), (14), (15).

Note: Control procedure (15) applies irrespective of outsourcing of any operations; that is to say, for IT as well as non-IT operations, and for RA as well as CA operations.

Additionally, the following requirement applies:

2.3A1 The CA SHALL implement and adhere to its information security policy.

2.4 Asset classification and management

The CA shall ensure that its assets are appropriately protected according to its CP.

Control procedures referenced in this Section refer to Section 7.4 of (ISO27099). The following control procedures SHALL be fulfilled as requirements:

(1), (2), (3), (4), (5), (6), (7).

2.5 Human resources security

The CA shall ensure that all employees possess expert knowledge, experience and qualifications necessary for the offered services and appropriate to the job function and that its personnel is trustworthy to ensure the integrity of the CA's operation.

Control procedures referenced in this Section refer to Section 7.5 of (ISO27099). Concerning the trustworthiness of personnel, the following control procedures SHALL be fulfilled as requirements:

(1), (2), (3), (4), (5), (6), (8), (9), (11).

Additionally, the following requirement applies:

- 2.5A1** The responsibilities bound to the roles at the CA and RA, and the boundaries of each of these responsibilities SHALL be well-defined in order to enable a clear structure in staff organization at the CA and RA.

2.6 Physical and environmental security

The CA shall ensure that physical access to its premise is restricted to authorized individuals. Furthermore, the CA shall implement measures to protect its premises from environmental threats and to prevent loss, damage or compromise of assets and interruption of business activities.

Control procedures referenced in this Section refer to Section 7.6 of (ISO27099). Concerning the physical and environmental security, the following control procedures SHALL be fulfilled as requirements:

(3), (4), (5), (8), (10), (11), (12), (13), (14), (17), (20), (21), (24), (25).

Additionally, the following requirements apply:

- 2.6A1** Physical access to CA facilities SHALL be limited to authorized individuals. For virtualised environments, the CA software SHALL be isolated from other software and access SHALL be limited to authorized individuals.
- 2.6A2** Security levels SHALL be defined for the premises of the CA, CA facilities, supplying facilities and/or parts of them. The access to the security levels SHALL be defined by an access list and SHALL be reviewed regularly. The physical protection SHALL be ensured by clearly defined security perimeters for the defined security levels.
- 2.6A3** All premises shared with external organizations SHALL be outside of the security perimeters.
- 2.6A4** Continuous power supply SHALL be ensured for all critical processes by an uninterruptible power supply (UPS) system.

2.7 Operational security

The CA shall ensure its correct and secure operation and that its operation is not disturbed or interrupted by system failures, malfunctions or incidents.

Control procedures referenced in this Section refer to Section 7.7 of (ISO27099). The following control procedures SHALL be fulfilled as requirements:

(1), (2), (3), (4), (5), (6), (7), (8), (9), (10), (11), (12), (13), (14), (15).

Additionally, the following requirements apply:

- 2.7A1** An analysis of the estimated usage of the CA services SHALL be done before setting-up the technical infrastructure. The performance of the technical infrastructure SHALL be sufficient for the requirements and scalable without interrupting the continuous operation.
- 2.7A2** Written procedures SHALL exist for all operational CA processes, including the information of the associated roles.
- 2.7A3** Persons who are involved in the registration process of applicants SHALL NOT be involved in the certificate generation process or vice versa.
- 2.7A4** The CA SHALL employ sufficient personnel for all critical services.
- 2.7A5** Penetration testing SHALL be conducted regularly, in a period of [assignment: number of days, weeks or months].

- 2.7A6** The CA SHALL define the maximal tolerable downtime of each service and tailor the services appropriately.

2.8 Access control

If access to the IT systems of the CA is not adequately secured, an intrusion by an attacker might be successful. This would result in loss of trust into any service provided by the CA. Therefore, the CA shall ensure that access to its IT systems is restricted to authorized personnel only.

Control procedures referenced in this Section refer to Section 7.8 of (ISO27099). The following control procedures SHALL be fulfilled as requirements:

(1), (2), (3), (5), (10), (11), (13), (15), (16), (17), (18), (19), (20), (21), (23), (25), (26).

Additionally, the following requirement applies:

- 2.8A1** Staff employed by the CA SHALL NOT have access to any service for which they are not explicitly authorized to use.

2.9 System acquisition, development and maintenance

The CA shall ensure the continuous operation of its systems and that the system's integrity is not affected by maintenance activities such as for example updates of the operating system.

Control procedures referenced in this Section refer to Section 7.9 of (ISO27099). The following control procedures SHALL be fulfilled as requirements:

(2), (3), (5).

Additionally, the following requirements apply:

- 2.9A1** Test PKI operations SHALL be operated strictly separated from productive PKI operations. This MAY be guaranteed by IT-based and/or organisational measures.
- 2.9A2** A productive CA SHALL NOT issue test certificates. This MAY be guaranteed by IT-based and/or organisational measures.

2.10 Business continuity management

The CA shall ensure timely and appropriate reaction to incidents to limit the damage to its business operation ensuring continuous liability and obligation towards subscribers and relying parties. Therefore, requirements for business continuity and incident handling are the focus of this section.

Control procedures referenced in this Section refer to Section 7.10 of (ISO27099). Concerning business continuity management the following control procedures SHALL be fulfilled as requirements:

(1), (2), (3), (4), (6), (9).

Additionally, the following requirements apply:

- 2.10A1** After an incident, the CA SHALL ensure that the security vulnerability, which caused the incident, is fixed or sufficiently mitigated. Afterwards, a timely restart of the services SHALL be processed.
- 2.10A2** For each defined role there SHALL be at least one substitute to limit negative effects on the process-flow conducted at the CA if an individual is unavailable to fulfil his or her role.
- 2.10A3** Data regarding CA operation SHALL be backed-up. This backup SHALL ensure the operation of the CA in case of an emergency. At least the backups of critical data SHALL be realized physically separated from regular operations.

2.11 Monitoring, conformance and compliance

The CA shall ensure that its operation is compliant to its security policy and to relevant legal and contractual requirements.

Control procedures referenced in this Section refer to Section 7.11 of (ISO27099). The following control procedures SHALL be fulfilled as requirements:

(4), (6), (8).

2.12 Audit journal security and archiving

The CA shall log and archive all events that are relevant with respect to the CA's operation as well as the key and certificate management. The set of information, which shall be archived and tracked, shall be clearly defined and shall contain all relevant information.

Control procedures referenced in this Section refer to Section 7.12 of (ISO27099). Concerning the archiving and tracking of relevant events, the following control procedures SHALL be fulfilled as requirements:

(1), (2), (3), (4), (8), (9), (11), (12), (14), (15), (18), (19).

Additionally, the following requirements apply:

2.12A1 The CA SHALL log CA key life cycle management related events. This SHALL include:

- CA key generation;
- manual installation of cryptographic keys (if supported);
- CA key back-up (if supported);
- CA key storage;
- CA key recovery (if supported);
- CA key escrow activities (if supported);
- CA key usage;
- CA key archival (if supported);
- CA key revocation (if supported);
- CA key destruction;
- identity of the entity authorizing a key management operation;
- identity of the entities handling any keying material (such as key components or keys stored in portable devices or media);
- custody of keys and of devices or media holding keys.

2.12A2 Audit trail data SHALL be append-only.

2.12A3 The CA SHALL ensure that a complete set of information concerning a certificate is archived. This set of information SHALL be

- clearly and a priori defined,
- stored for an a priori defined, appropriate time, and
- unambiguously be referred to a certificate.

2.12A4 The set of information to be archived and the period of time for keeping the archived information SHALL be defined in the CA's Terms and Conditions. For each event to be archived, the event time SHALL be recorded precisely.

- 2.12A5** The archived set of information, the mapping onto certificates and to the registered subscribers SHALL be sufficient for all applicable processes of certificate renewal, re-keying and update.

2.13 Controlled CA termination

In this section requirements for a controlled termination of CA operation are specified.

Control procedures referenced in this Section refer to Section 7.15.9 of (ISO27099). Concerning the cessation of operation of a CA, the following control procedures SHALL be fulfilled as requirements:

(1), (5), (7), (8), (9).

Additionally, the following requirement applies:

- 2.13A1** If no successor instance for a transition period is defined and guaranteed for the case of CA termination, the CA SHALL have a guaranteed plan for an alternative secure termination of all services.

3 Key life cycle management

A cryptographic key has several states during its life. The typical key lifecycle in the context of CA operation comprises the following states: key generation, key storage, key backup, key recovery, key distribution, key usage, key archival and key destruction.

The CA shall ensure that the security of cryptographic keys is maintained during the whole key lifecycle. This holds for the CA's own key as well as for those keys that are owned by subjects and the CA issues corresponding certificates for.

In this section requirements concerning the key lifecycle management are specified. Thereby, requirements concerning the management of the CA's own key relate to Section 7.13 of (ISO27099) and are addressed in subsection 3.1. Requirements concerning subject keys relate to Section 7.14 of (ISO27099) and are specified in subsection 3.2

3.1 CA key life cycle management

The private key of the CA is used by the CA for example to sign certificates or to sign certificate revocation lists. The private key of a CA forms the basis for the CA's trustworthiness. Therefore, the CA shall ensure that its own CA key pair, in particular its own private key, is maintained securely during the whole key life cycle.

Note that a CA may use separate key pairs with corresponding certificates to sign certificates, revocation lists and to issue OSCP signers. In this case the CA SHALL ensure that all of the CA's own key pairs are maintained securely corresponding to this section.

The following requirement concerning the key life cycle management SHALL be fulfilled by the CA for the CA's own key:

- 3.1A1** Private keys of the CA SHALL be generated and handled in a certified security device compliant with [assignment: Security Level 2 according to (KLSR), (ISO15408), equivalent, appropriate application specific requirements] ensuring the claimed security features, including tamper resistance, mitigation of side channels, suitable access control, random number generator and security of cryptographic operations. An appropriate access control SHALL ensure that the keys are not accessible from outside.
- 3.1A2** Private keys of the CA SHALL be handled (e.g. generated, stored, used or recovered) only by personnel in trusted roles.

3.1.1 CA key generation

Control procedures referenced in this Section refer to Section 7.13.1 of (ISO27099). Concerning the generation of the CA's own key pair, the following control procedures SHALL be fulfilled as requirements:

(3), (4), (5), (7), (10), (12).

Additionally, the following requirement applies:

- 3.1.1A1** The generation of a new key pair and the corresponding CA certificate SHALL be done at least [assignment: number of days more than 2] days before the private key usage period of the previous CA certificate ends.

3.1.2 CA key storage, backup, and recovery

Control procedures referenced in this Section refer to Section 7.13.2 of (ISO27099). Concerning the storage, backup and recovery of the CA's own key, the following control procedures SHALL be fulfilled as requirements:

(2), (5), (7), (8).

Additionally, the following requirements apply:

- 3.1.2A1** Backups of the CA keys SHALL be made.
- 3.1.2A2** If private keys of the CA are stored outside the security device (e.g. as backup), the private keys SHALL be processed with the same level of protection as defined by requirement **3.1A1**.
- 3.1.2A3** Any storage media containing backups of private keys SHALL be encrypted and secured against non-authorized usage. The storage media SHALL be located in a physically and logically highly secured area. Access to this area SHALL be restricted to an appropriate set of persons which is clearly defined by their roles. The number of authorized persons SHALL be restricted, while ensuring staff availability to carry out these tasks.

3.1.3 CA public key distribution

Control procedures referenced in this Section refer to Section 7.13.3 of (ISO27099). Concerning the distribution of the CA's own public key, the following control procedures SHALL be fulfilled as requirements:

(1), (5).

Additionally, the following requirement applies:

- 3.1.3A1** The public key fingerprint of a CA certificate SHALL be disseminated to the relying parties on a different channel than the corresponding CA certificate.

3.1.4 CA key usage

Control procedures referenced in this Section refer to Section 7.13.4 of (ISO27099). Concerning the usage of the CA's own key, the following control procedures SHALL be fulfilled as requirements:

(1), (2), (3), (5).

Additionally, the following requirement applies:

- 3.1.4A1** To decrease the chances for misuse of the CA private key, the private key SHALL only be set active for the period necessary. Therefore, the private key SHALL be deactivated if one of following cases occurs:
 - the key is intended not to be used until a fixed date, e.g. for disseminating the new certificate before it will be used;
 - the key is no longer in use because a new private key has been activated;
 - it is obvious that the key will not be used for a period of [assignment: number of days, weeks or months] due to a special use case.
- 3.1.4A2** For the activation of the key material, hardware tokens (e.g. smart cards) SHALL be used.

3.1.5 CA key archival and destruction

Control procedures referenced in this Section refer to Section 7.13.5 of (ISO27099). Concerning the archival and destruction of the CA's own key, the following control procedures SHALL be fulfilled as requirements:

(1), (3), (4), (5), (6), (7), (9).

Additionally, the following requirement applies:

- 3.1.5A1** Archived public keys SHALL only be used when historical evidence requires validation.

3.1.6 CA key compromise

Control procedures referenced in this Section refer to 7.13.6 of (ISO27099). Concerning the compromise of the CA's own key, the following control procedures SHALL be fulfilled as requirements:

(1), (2).

3.2 Subject key life cycle management

A certificate is issued by a CA and binds the public key of a key pair to a subject. Depending on the issuing CA and its role within a PKI hierarchy, the subject in the issued certificate can be again a CA or an end entity. Despite of the type of the subject, CA or end entity, this section specifies requirements concerning the life cycle of subject keys and refers to Section 7.14 of (ISO27099).

Concerning the secure handling of subject keys throughout the whole subject key life cycle, the following requirements apply:

- 3.2A1** The requirements on hard- and/or software to be used for handling (e.g. key generation or storage) of subject keys SHALL be specified by the CA in its Terms and Conditions.
- 3.2A2** To prevent unauthorized access to or alteration of subject keys, the CA SHALL define in its Terms and Conditions the subscriber (and where applicable subject) obligations concerning the subscribers' (and where applicable subjects') operational environment.
- 3.2A3** The CA SHALL define in its Terms and Conditions subscriber (and where applicable subject) obligations concerning the subscriber's (and where applicable subject's) processes and operation environment for all subject key operations.
- 3.2A4** The CA SHALL specify in its CP requirements and limitations for the usage of subject keys. All certificates issued by this CA SHALL contain information on the subject key usage correspondingly (cf. KeyUsage according to (RFC5280)). The CA SHALL define in its Terms and Conditions the obligations for subscribers (and where applicable of subjects) concerning the usage of subject keys.
- 3.2A5** Subject private keys SHALL be handled (e.g. generated, stored, used or recovered) only by trusted individuals.

3.2.1 Subject key generation and distribution

There are two alternative ways how the subject key pair can be generated and provided:

- The subject key pair is generated at the subject's or subscriber's premise and the public key is provided by the subject or subscriber during the identification and registration process to the issuing CA. This alternative is addressed in subsection 3.2.1.1.
- The CA generates a key pair on behalf of the subject, issues the corresponding certificate and delivers it to the subject or subscriber in a secure manner. Requirements for this alternative are described in subsection 3.2.1.2.

Despite of which alternative is chosen for subject key generation and distribution, the following requirement applies:

- 3.2.1A1** The CA SHALL implement mechanisms to correctly assign the subject's public key to the registration data.

3.2.1.1 Subject keys provided by subscriber (if supported)

If subject key generation by the subscriber is supported by the CA, the CA shall define, e.g. in its CP or Terms and Conditions, which ways of key pair derivation are allowed, which technical requirements have to be fulfilled for key generation, and oblige subscribers to follow these requirements.

If subject key generation by the subscriber is supported by the CA, the following requirements concerning the subject key generation apply:

- 3.2.1.1A1** The CA SHALL determine the security level of the supported subscriber applications by considering a risk analysis of the business case and if applicable of legal requirements.

For subscriber applications with security level 'high', as e.g. Sub-CAs or qualified electronic signatures, the CA SHALL demand the usage of cryptographic modules (HSM or token) for the handling of subject keys, in particular for key generation and key storage.

For subscriber applications with lower security level, the CA SHALL at least demand from subscribers to adopt the following security measures: use of virus protection, use of software firewall, installation of operating system security updates when they occur, [assignment: additional security measures].

3.2.1.1A2 The registration data SHALL be clearly defined by the CA and SHALL contain the public key of the subject and all subject attributes that are necessary for the registration process. At least the public key and the subject attributes SHALL be signed with the subject's private key to avoid alteration and to provide proof of possession of the private key. The CA SHALL verify this signature.

3.2.1.1A3 The CA SHALL validate if the subject key pair fulfils the cryptographic requirements. The CA SHALL refuse the certificate request and SHALL NOT generate a corresponding certificate if these requirements are not fulfilled.

3.2.1.2 Subject keys provided by the CA (if supported)

The second alternative for subject key generation is that the CA generates the subject's key pair and disseminates it to the subscriber or subject. Note that when using this method the subject has not the exclusive control over its own key pair. This may be not allowed in many PKI use cases.

Control procedures referenced in this Section refer to Section 7.14.1 of (ISO27099). If the subject key is generated by the CA on behalf of the subject the following control procedures SHALL be fulfilled as requirements:

(2), (3), (4), (5), (6)

Additionally, the following requirements apply:

3.2.1.2A1 The CA SHALL describe the key dissemination procedure in its Terms and Conditions.

3.2.1.2A2 The CA SHALL determine the security level of the supported subscriber applications by considering a risk analysis of the business case and if applicable of legal requirements.

For subscriber applications with security level 'high', as e.g. Sub-CAs or qualified electronic signatures, the CA SHALL demand the usage of a certified security device compliant with [assignment: Security Level 2 according to (KLSR), (ISO15408), equivalent, appropriate application specific requirements] for the handling of subject keys, in particular for key generation and key storage. . An appropriate access control SHALL ensure that the keys are not accessible from outside.

For subscriber applications with lower security level, the CA SHALL at least demand from subscribers to adopt the following security measures: use of virus protection, use of software firewall, installation of operating system security updates when they occur, [assignment: additional security measures].

3.2.1.2A3 If the private key has been provided to the subscriber and is not needed anymore for key storage, recovery, or back-up services, the CA SHALL destroy this private key, including any copies, without undue delay.

3.2.2 Subject key storage, backup and recovery

Concerning the secure storage, backup or recovery of subject keys, the following requirements apply:

3.2.2A1 If private keys of subscribers/subjects are stored outside the security device (e.g. as backup), the private keys SHALL be processed with the same level of protection as defined in Section 3.2.1.

3.2.2A2 Any storage media containing backups of private keys SHALL be encrypted and secured against non-authorized usage.

3.2.2.1 Subject key storage, backup and recovery services provided by CA (if supported)

Control procedures referenced in this Section refer to Section 7.14.2 of (ISO27099). If the CA provides key storage, backup or recovery services of subject keys, the following control procedures SHALL be fulfilled as requirements:

(1), (2), (3), (4), (5), (6), (7), (8), (10).

Note: Unlike in (ISO27099), Section 7.14.2, key escrow services are not in the scope of this Technical Guideline.

Additionally, the following requirement applies:

3.2.2.1A3 Any storage media containing backups of private keys SHALL be located in a physically and logically highly secured area. Access to this area SHALL be restricted to an appropriate set of persons which is clearly defined by their roles. The number of authorized persons SHALL be restricted, while ensuring staff availability to carry out these tasks.

3.2.3 Hardware token life cycle management (if supported)

If subject key pair generation is provided by the CA (see section 3.2.1.2), the CA may decide to generate a “personalized” token on which the subject key pair and certificate is stored and which is disseminated to the subscriber. In this case the trustworthy management of the token is essential in order to ensure the confidentiality of the subject key pair and the integrity of the corresponding certificate. The key pair can either be loaded to the token by the CA or is generated by the token itself. If desired, the keys generated by the token can be identified by using a serial number or a token-specific certificate. The secure functioning and correct preparation of the cryptographic hardware prevent the certificates from being compromised.

Control procedures referenced in this Section refer to Section 7.14.3 of (ISO27099). The following control procedures SHALL be fulfilled as requirements:

(2), (5), (6), (7), (8), (11), (12), (14), (15), (19).

Additionally, the following requirements apply:

3.2.3A1 The CA SHALL ensure that the hardware token (cryptographic hardware) is appropriate to the security requirements of the certificates throughout its life cycle and as defined in the CP.

3.2.3A2 The CA SHALL correctly assign the hardware token and the public key from the hardware token to the subscriber’s registration data.

3.2.3A3 The CA SHALL describe the dissemination procedure for hardware tokens in its Terms and Conditions.

3.2.3A4 The CA SHALL use the registered subscriber data to ensure that the hardware token is disseminated to the correct subscriber.

3.2.3A5 When detecting a compromise of the PIN code during the activation procedure, the subscriber SHALL be obliged by the CA’s Terms and Conditions to inform the CA. In this case the affected certificate SHALL be revoked.

3.2.4 Subject key archival and destruction (if supported)

Control procedures referenced in this Section are based upon Section 7.13.5 of (ISO27099) but do not apply to the CA’s own key but to the subject key. If the CA provides archival or storage services of subject keys, the following requirements concerning the archival and destruction of subject keys apply:

- 3.2.4A1** Subject private keys SHALL be archived with the same or a greater level of security as keys currently in use.
- 3.2.4A2** Archived keys SHALL only be used when historical evidence requires validation.
- 3.2.4A3** The CA SHALL define in its CPS how the subject's private key has to be destroyed (e.g. hardware token surrender, hardware token destruction or key overwrite).
- 3.2.4A4** All copies and fragments of the subject's private key SHALL be destroyed such that the private key cannot be retrieved.
- 3.2.4A5** The CA shall destroy the subject private key and all the backups after revocation or regular end of validity of the corresponding subject certificate.
- 3.2.4A6** Destruction of subject keys shall be undertaken in a physically secured environment by authorized and trusted personnel under the principles of multiple control.

4 Certificate life cycle management

Like cryptographic keys, certificates have several states during their life. According to (ISO27099) a certificate may be pre-valid, live, suspended (if supported), revoked or expired. During each of these states the security and trustworthiness of certificates shall be maintained by the CA.

In this section the requirements for the different tasks of a CA during the certificate life cycle are specified.

4.1 Subject registration

A certificate binds the public key of a key pair to the identity of a subject (e.g. person or organization). Therefore, it is essential to ensure the correct identification of subjects. This identification is part of the responsibility of the CA. It should be specifically done by non-electronic means. A subscriber shall provide documentation for identification to the CA, while the CA checks the identity of this subscriber based on the provided documentation. Furthermore, the CA shall ensure that certificate requests are correct, complete and authorized.

Control procedures referenced in this Section refer to Section 7.15.1 of (ISO27099). Concerning the subject registration the following control procedures SHALL be fulfilled as requirements:

(1), (2), (3), (4), (5), (6), (7), (8), (10), (11), (12), (13).

Additionally, the following requirements apply:

- 4.1A1** The formal process-flow including the interfaces for requesting the registration and/or providing information by the subscriber SHALL be clearly defined and verified by the CA or RA.
- 4.1A2** The CA SHALL oblige subscribers to notify the CA immediately about any change of their registration data. Additionally, the CA SHALL require a confirmation from the subscriber that the registration data is still valid at least every [assignment: number of months] months.
- 4.1A3** The CA SHALL verify the information identifying the subscribers and the physical existence directly or indirectly using appropriate measures. The physical address or other appropriate attributes for contact SHALL be verified.
- 4.1A4** The CA SHALL define clearly the set of information identifying the subscriber. If the subject differs from the subscriber, additional information (e.g. evidence of legitimation to act on behalf of subject) SHALL be provided and checked. In case of a physical person associated with a legal person, this association SHALL be verified.
- 4.1A5** The CA SHALL check its database to determine if a subject has registered before so that multiple identities of a subject are linked within the registration database and can be suspended at once or prevented totally if required by the Terms and Conditions.
- 4.1A6** The CA SHALL ensure, that the requesting subject is identified unambiguously before starting the certificate generation process.

4.2 Certificate renewal (if supported)

The renewal of a certificate is defined as extending the validity period of a certificate. The public key of the subscriber and the subscriber information of the certificate are not modified. The certificate may be signed with a different private key of the CA than the one used originally.

If certificate renewal is supported by the CA, the CA shall provide an appropriate process for renewal and that it is processed in a timely manner.

Control procedures referenced in this Section refer to Section 7.15.2 of (ISO27099). If Certificate renewal is supported the following control procedures SHALL be fulfilled as requirements:

(2), (3), (4), (5), (6), (8), (9), (12), (13), (14).

Additionally, the following requirements apply:

- 4.2A1** The CA SHALL check carefully, if the renewal of a certificate is necessary. Therefore, the need for a renewal instead of re-keying demanded by the business case SHALL be balanced with the security risk of the weakened key pair, the validity period of the certificate and the used algorithms. In case of doubt, re-keying of the certificate SHALL be done.
- 4.2A2** For the case of expiring certificates, the CA SHALL define in the CP and/or CPS that a request for the renewal of a certificate SHALL be submitted at least [assignment: number of days or weeks] before the previous certificate expires. The CA SHALL be able to generate the new certificate within the defined timeframe.
- 4.2A3** The CA SHALL define clearly in its Terms and Conditions in which cases renewal may be allowed.

4.3 Certificate rekey

Rekeying of a certificate is defined as issuing a new certificate based on a newly generated subscriber key pair and a new validity period. The remaining content of the certificate (i.e. the attributes of the subscriber) stays usually unchanged.

The CA shall provide an appropriate process for certificate rekeying and that it is processed in a timely manner.

Control procedures referenced in this Section refer to Section 7.15.3 of (ISO27099). Concerning rekeying of a certificate the following control procedures SHALL be fulfilled as requirements:

(1), (2), (3), (5), (8).

Additionally, the following requirements apply:

- 4.3A1** For the case of expiring certificates, the CA SHALL define in the CP and/or CPS that a request for the rekeying of a certificate SHALL be submitted at least [assignment: number of days or weeks] before the previous certificate expires. The CA SHALL be able to generate the new certificate within the defined timeframe.
- 4.3A2** The CA SHALL enforce the use of a newly generated key pair.

4.4 Certificate issuance

When issuing a certificate, a certificate is generated by signing the public key and additional information of the subject with the private key of the CA. By signing a certificate with its private key the CA provides trust in the certificate of the subject and thus in the subject itself. Therefore, the CA shall ensure correct and secure generation of certificates.

Control procedures referenced in this Section refer to Section 7.15.4 of (ISO27099). Concerning certificate issuance the following control procedure SHALL be fulfilled as requirement:

(4).

Additionally, the following requirements apply:

- 4.4A1** CA SHALL NOT allow issuance of identical certificate attributes for two different key pairs.
- 4.4A2** Certificates SHALL include the following attributes which SHALL be verified by the CA:
 - identification of the CA (cf. “issuer” according to (RFC5280)),
 - name of the subscriber or the identifiable subject,
 - additional relevant attributes of the CA or subject/subscriber,

- public key corresponding to the private key under the subscriber control,
- period of validity,
- the certificate serial number,
- the electronic signature of the issuing authority,
- limitation of the scope of the certificate,
- limitations on transactions,
- information about the cryptographic algorithms of the issuing authority's signature and of the public key of the subscriber.

4.4A3 The CA SHALL be able for all disseminated certificates to associate unambiguously a certificate to the subject the respective certificate has been disseminated to.

4.4A4 The CA SHOULD differentiate between private key usage and validity period of the public key.

4.5 Certificate distribution

The CA shall ensure that it only disseminates valid and correct certificates to the certificate holder and the relying parties.

Control procedures referenced in this Section refer to Section 7.15.5 of (ISO27099). Concerning the distribution of certificates, the following control procedures SHALL be fulfilled as requirements:

(1), (2), (3).

4.5.1 Directory Service (if supported)

A directory service is a mechanism to publish certificates and certificate status information to the relying parties.

If a directory service is supported, then following requirements apply:

4.5.1A1 The Directory Service SHALL provide a searchable repository that contains all certificates that are issued by this CA and their certificate status information.

4.5.1A2 The publication of a certificate, i.e. the delay between issuance of a certificate and its availability on the directory service to all relying parties, SHALL be at most [assignment: number of hours/days].

4.5.1A3 The Directory Service SHALL provide secure communication and adequate controls in order to prevent unauthorized entities from adding, modifying, or deleting repository entries. The exact control mechanisms SHALL be part of the respective CPS.

4.5.1A4 The Directory Service SHALL grant access to all relevant information to the relying parties.

4.6 Certificate changeover (if supported)

Root-CAs and only root-CAs may use link certificates in order to ensure a secure transition from the current to the successor Root CA certificate. If a certificate changeover by means of link certificates is supported by a root-CA, the following requirement applies:

4.6A1 For a root-CA changeover, the root-CA SHALL generate two certificates: a self-signed successor certificate and a link certificate. The link certificate SHALL contain the public key and the attributes of the successor certificate and SHALL be signed with the private key of the currently valid root-CA certificate. If the root-CA implements a directory service, these two certificates SHALL be published on the root-CA's directory service to enable the verification of the integrity and authenticity of the successor root-CA certificate.

- 4.6A2** The root-CA changeover SHALL be performed with a preloading phase of at least [assignment: number of days/months]. Therefore, the successor certificate of the CA SHALL be generated accordingly to that preloading phase before its validity starts. During this preloading phase the successor certificate and the link certificate SHALL be securely distributed to all relying parties. The preloading phase ensures that from the beginning of the validity of the successor certificate all relying parties are able to verify certificates and CRLs that are issued with the newly generated successor certificate.

Concerning the secure transition from a CA certificate to the succeeding CA certificate the following requirements apply for both, root-CA and sub-CA:

- 4.6A3** The CA changeover SHALL be performed with an overlap time of at least [assignment: number of days/months] up to at most [assignment: number of days/months] in order to ensure a secure transition from the current to the successor CA certificate. The overlap time starts at the same time as the validity of the successor certificate starts.
- 4.6A4** After expiration of the overlap time, the private key including backup keys of the current CA certificate SHALL be securely deleted.
- 4.6A5** The CA SHALL use its newest private key for issuing certificates. That means that a CA's private key SHALL NOT be used anymore for issuing certificates, once a successor certificate becomes valid. Thus, at any point in time there is exactly one private key in usage for issuing certificates.
- 4.6A6** The CA SHALL use its newest private key for signing its Certificate Revocation List. That means that a CA's private key SHALL NOT be used anymore for signing CRLs, once a successor certificate becomes valid. Thus, at any point in time there SHALL be only one private key in usage for signing the Root CA's or Sub CA's Certificate Revocation List.²

4.7 Certificate revocation

The reliability of issued certificates cannot be ensured unconditionally. In order to counter the hopefully few cases, where a certificate is not trustable anymore, for example because it has been issued wrongfully or a private key has been compromised, it shall be possible to revoke trust in certificates.

The CA shall provide an appropriate process for certificate revocation and that revocation is processed in a timely manner. Furthermore, the CA shall make the revocation status of certificates available to subscribers and relying parties.

Control procedures referenced in this Section refer to Section 7.15.6 of (ISO27099). Concerning the revocation of certificates the following control procedures SHALL be fulfilled as requirements:

(1), (2), (4), (6), (7), (8), (9), (10).

Additionally, the following requirements apply:

- 4.7A1** If a legitimate revocation request is received, the CRL, OCSP responder (if supported), or other certificate status information mechanisms SHALL be updated by the CA in the respective time frames specified within the CP.
- 4.7A2** The complete revocation process (i.e. the delay between a revocation request or report and the availability of the revocation status information to all relying parties) SHALL be at most [assignment: number of hours] hours.
- 4.7A3** Certificate status information SHALL be backed up to a physically separated server to avoid the loss of data.

² Note that although the CRL is always signed with the newest private key of the CA, the CRL can include revoked certificates that are issued by this CA with its newest private key as well as revoked certificates that are issued by this CA with one of its earlier private keys.

- 4.7A4** The integrity of the revocation information, both of the original and the back-ups, SHALL be secured by appropriate cryptographic measures.
- 4.7A5** The service processing the revocation of certificates SHALL ensure the processing of inquiries and updates within [assignment: number of hours] hours.
- 4.7A6** The CA SHALL provide a service receiving the revocation or suspension request by subscribers or third parties. This service shall be available as required by the application context or business case, respectively.
- 4.7A7** The CA SHOULD document and archive each revocation request and actually performed revocation in a comprehensible way. This documentation and archiving SHALL include at least:
- entity that applied for revocation of a certificate,
 - name of revoked subject if present and known at time of revocation,
 - serial number of revoked certificate if present and known at time of revocation,
 - reasonable evidence for the legitimacy of the revoking party,
 - date and time of revocation,
 - date and time of invalidity, and
 - revocation reason.
- 4.7A8** After a revocation of a subject's certificate, a new certificate for this subject SHALL be requested following the process of initial application.
- 4.7A9** After a revocation of a subject's certificate, the CA SHALL create new certificates for the subject with a new key pair.

4.8 Certificate suspension (if supported)

Like revocation of a certificate, it may be supported by a CA to suspend certificates or subscribers.

If a certificate is suspended, it is temporarily not trustable. A suspension of a certificate will either be turned into a revocation or discarded. In the last case the certificate is again considered valid and trustable.

A subscriber will be suspended, if the subscriber is assumed or known to no longer fulfil the subscriber obligations. In the case of a subscriber suspension, the CA shall not issue new certificates for this subscriber and every certificate of the subscriber issued before shall be revoked or at least suspended.

If suspension is supported by the CA, the CA shall provide an appropriate process for suspension and shall ensure that suspension is processed in a timely manner.

The suspension status information is used for internal purposes, such as determining the subscriber authorization within the certificate generation process, and external purposes such as providing revocation information for relying parties on single certificates.

Control procedures referenced in this Section refer to Section 7.15.7 of (ISO27099). If suspension is supported by the CA, the following control procedures SHALL be fulfilled as requirements:

(1), (2), (3), (4), (5), (9), (10), (13), (14), (15).

Additionally, the following requirements apply:

- 4.8A1** Certificate suspension entries SHALL remain on the CRL until the expiration of the underlying certificate or the expiration of the suspension, whichever is first. The CP MAY specify a maximum number for how often the certificate status may be suspended and a maximum time-period for the suspension status.

- 4.8A2** The complete suspension process (i.e. the delay between a suspension request or report and the availability of the suspension status information to all relying parties) **SHOULD** be at most [assignment: number of minutes] minutes.

4.9 Revocation status information service

The CA shall ensure that revocation information are up-to-date and available for subscribers and relying parties. This ensures that relying parties can check if a certificate is revoked or still valid. Therefore, the CA shall provide the technical infrastructure to provide such service. The technical infrastructure provided by the CA shall be tailored for the estimated traffic.

Control procedures referenced in this Section refer to Section 7.15.8 of (ISO27099). Concerning the revocation status information service the following control procedure **SHALL** be fulfilled as requirements:

(1).

The following control procedures **SHALL** be fulfilled as requirements if CRLs are used:

(2), (3), (4), (5), (6), (7).

The following control procedures **SHALL** be fulfilled as requirements if online certificate status mechanisms (e.g. OCSP) are used:

(9), (10).

Additionally, the following requirements apply (for CRL and OCSP):

- 4.9A1** The CA **SHALL** ensure that that the revocation information is continuously available and accessible to the relying parties.
- 4.9A2** The CA **SHALL** ensure that the provided revocation information is up to date.
- 4.9A3** The Servers hosting the maintained revocation information **SHALL** be hardened against failure and attacks. The hardening against failure and attacks **SHALL** be based on the risk analysis.

4.10 Validation Model

The validation model determines the conditions under which a signature is considered valid. Usually the Shell or Hybrid Model are used.

Within the Shell Model a signature is valid if all certificates in the certificate chain are valid at the time of validation.

Hybrid Model and Modified Shell Model are often used synonymously. The Hybrid Model denotes that a signature is valid if all certificates in the certificate chain are valid at the time of signing.

A certificate is valid if the time of signing or validation is within the validity period of the certificate, the certificate is not revoked (cf. revocationDate according to (RFC5280)) at time of signing or validation and it is not invalid (cf. invalidityDate according to (RFC5280)) at time of signing or validation. Note that a certificate can be declared invalid in retrospective.

Concerning the validation model the following requirements apply:

- 4.10A1** Within the whole PKI in which the CA is active, one validation model **SHALL** be consistently applied. That means that the CA **SHALL** ensure a consistent application of the validation model for all of its operations such that the validity periods of all certificates in a certificate chain are chosen according to the chosen validation model.
- 4.10A2** In general, the Shell Model **SHOULD** be used. If the CA uses a different validation model, the CA **SHALL** justify its reasons.

Bibliography

- BSI-TR-02102 *Bundesamt für Sicherheit in der Informationstechnik: Kryptographische Verfahren: Empfehlungen und Schlüssellängen.*
- BSI-TR-03107 *Bundesamt für Sicherheit in der Informationstechnik: Elektronische Identitäten und Vertrauensdienste im E-Government, Teil 1: Vertrauensniveaus und Mechanismen.*
- BSI-TR-03116 *Bundesamt für Sicherheit in der Informationstechnik: Kryptographische Vorgaben für Projekte der Bundesregierung.*
- BSI-TR-03145 Bundesamt für Sicherheit in der Informationstechnik: Secure CA operation.
- ETSI102042 ETSI TS 102 042: Policy requirements for certification authorities issuing public key certificates.
- ISO15408 ISO/IEC 15408: Information technology -- Security techniques -- Evaluation criteria for IT security.
- ISO27001 ISO/IEC 27001: Information security management systems — Requirements. 2022.
- ISO27099 ISO/IEC 27099: Information technology — Public key infrastructure — Practices and policy framework. 2022.
- KLSR Bundesamt für Sicherheit in der Informationstechnik: Key Lifecycle Security Requirements.
- RFC2119 Bradner, S.: *Key words for use in RFCs to Indicate Requirement Levels.* <https://datatracker.ietf.org/doc/html/rfc2119>. IETF.
- RFC3647 Chokhani, S.; Ford, W.; Sabett, R.; Merrill, C.; Wu, S.: *RFC3647 Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework.* <https://datatracker.ietf.org/doc/html/rfc3647>. IETF.
- RFC5280 Cooper, D.; Santesson, S.; Farrell, S.; Boeyen, S.; Housley, R.; Polk, W.: *RFC5280 Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile.* <https://datatracker.ietf.org/doc/html/rfc5280>. IETF.